Cybersecurity Risk Management & Policy Improvement: Suncoast Credit Union

Carlos Bolivar, Lee Bernard | Mentor: Chengyi Qu | Florida Gulf Coast University | CIS 5377 – 16768 – Information Security and Compliance | Spring 2026

INTRODUCTION

Suncoast Credit Union is Florida's largest credit union (1M+ members, ~$17B assets, ~3,000 employees), processing thousands of daily transactions with sensitive member PII and financial data. The Financial Services sector is among the highest-value DHS-designated critical infrastructure targets: cybersecurity failures risk financial loss, regulatory penalties, and irreversible erosion of member trust.

PROBLEM DEFINITION

- Phishing / Social Engineering: targeting employees & members; highly effective
- Ransomware attacks: recovery averaging millions; frequency rising rapidly
- Insider threats: malicious or accidental; risk to member data & core banking
- Unauthorized access: weak authentication, excessive user privileges
- Third-party / vendor risk: underassessed, indirect entry points for attackers

ORGANIZATION & REGULATORY CONTEXT

HQ: Tampa, FL **Members:** 1,000,000+

Assets: ~$17B **Employees:** ~3,000

Regulatory obligations:

GLBA | PCI-DSS | NCUA | FFIEC | NIST CSF | CFPB | OFR | FIPA

NIST CSF ACTION PLAN

IDENTIFY	Full asset inventory & data classification · Annual third-party vendor risk assessments
PROTECT	MFA on all employee & admin accounts · Least-privilege access + quarterly reviews · Endpoint encryption & patch management · Security awareness training + phishing sims
DETECT	SIEM (Splunk/Sentinel) + 24/7 monitoring · EDR on all endpoints
RESPOND	Formalized IRP with defined IRT roles · Regulatory notifications per GLBA/NCUA
RECOVER	Encrypted offsite backups; quarterly testing · RTO: 4 hrs | RPO: 24 hrs

RISK MANAGEMENT ANALYSIS

Risk	Like.	Impact	Rating
Phishing / Social Engineering	High	High	CRITICAL
Unauthorized Access / Credential Theft	High	High	CRITICAL
Ransomware Attack	Med	High	HIGH
Insider Threat	Med	High	HIGH
Third-Party / Vendor Breach	Med	High	HIGH
Data Breach (PII / Financial)	Med	High	HIGH
DDoS on Banking Services	Low	Med	MEDIUM
Unpatched Vulnerabilities	Med	Med	MEDIUM

THREATS & VULNERABILITY ASSESSMENT

NETWORK & SYSTEM

- MitM on transactions
- DDoS on banking
- Ransomware encryption
- Unpatched software / ATM malware

DATA & USER

- Exfiltration of member PII
- DB injection attacks
- Phishing / vishing staff
- Credential stuffing

Auth: MFA not on all systems **Access:** Excess privileges

Data: Legacy encryption gaps **Backup:** Untested backups

INFORMATION SECURITY POLICY (ISP) DRAFT

ACCEPTABLE USE
Authorized business only; personal use of banking infra prohibited; violations disciplined

ACCESS CONTROL
Least-privilege; supervisor approval; quarterly reviews; revoked within 24 hrs of termination

PASSWORD & MFA
14+ char passwords, 90-day rotation; MFA mandatory for remote access, admin & PII systems

INCIDENT RESPONSE
Report to IT Security within 1 hr; IRT classifies, contains & remediates per regulatory timelines

BACKUP & RECOVERY
Daily encrypted backups to separate geo locations; tested quarterly; RTO: 4 hrs / RPO: 24 hrs

COMPLIANCE & AUDIT
Annual internal audits + 3rd-party pen tests; GLBA, PCI-DSS, NCUA compliance documented annually

CURRENT VS. PROPOSED APPROACH

Area	Current State	Proposed
MFA Coverage	Member-facing only	All employee systems
Incident Response	Basic (assumed)	Formalized, tested, defined
Vendor Risk	Ad-hoc assessments	Annual structured reviews
Employee Training	Standard onboarding	Phishing sims + certification
SIEM / Monitoring	Unknown depth	Full SIEM + 24/7 SOC

PROPOSED INVESTMENT COSTS

Platform / Solution	Est. Annual Cost
SIEM (Splunk/Sentinel)	$50K–$120K
MFA (Duo Security)	$360K–$540K
EDR Solution	$30K–$80K
Penetration Testing	$20K–$50K
Security Awareness (KnowBe4)	$15K–$30K
Backup & DR Upgrade + IR Retainer	$65K–$160K
Estimated Annual Total	**~$500K–$980K**

ANTICIPATED RESULTS

PHISHING PREVENTION	MEAN TIME TO DETECT	RECOVERY TIME (RTO)	COMPLIANCE
↓80%	30d	4 hrs	Full
via MFA + training	via SIEM + 24/7 SOC	critical systems	GLBA, PCI, NCUA

CONCLUSION

This comprehensive project involved an extensive examination of Suncoast's overall cyber risk landscape, which ultimately led to the development of a robust Information Security Program (ISP). The proposed action plan is meticulously aligned with the NIST Cybersecurity Framework (CSF) and is specifically designed to address and mitigate critical threats such as phishing, ransomware, and unauthorized access by mapping targeted defensive strategies across all five core NIST functions.

Within the global marketplace, the Financial Services sector continues to stand as one of the highest-value targets for sophisticated cyber adversaries. Consequently, credit unions are subject to increasingly strict and evolving regulatory demands that necessitate a constant state of improvement regarding organizational governance, technical security controls, and general workforce readiness. Implementing a proactive, policy-driven cybersecurity posture is therefore indispensable for the ongoing protection of member trust and the long-term integrity of financial operations.

When weighing the estimated $500K–$980K annual operating cost of this initiative against the potential $4.9M devastating impact of a single major data breach, it's clear that this program represents an exceptionally strong and strategically sound risk-adjusted investment for the organization's future.

[1] NIST CSF 2.0 (2024) [2] NIST CSF 1.1 (2018) [3] CISA Financial Services (2023) [4] IBM Cost of Breach (2024) [5] NCUA (2023) [6] FFIEC CAT (2015) [7] PCI DSS v4.0 (2022) [8] CIS Controls v8 (2023) [9] GLBA 15 U.S.C.§§6801–6827 [10] Verizon DBIR (2024) [11] Suncoast CU (2024) [12] DHS CISA (2023)